Quiz Bank: Quizzes 1 and 2 (facilitator only)

Oct 19, 2026 · @Nenji

Keep this document private: it holds the answer keys for both runs (face-to-face 21 October, online 26 October 2026).

How to use

Each quiz goes into an auto-graded form (Google Forms or Microsoft Forms, whichever ILCDB approves), one form per run, so the online run cannot see the face-to-face answers.

Setting	Quiz 1	Quiz 2
Items and time	15 items, 20 minutes	12 items, 15 minutes
Weight	10%	10%
When (face-to-face)	Wed 21 Oct, 11:25 AM	Wed 21 Oct, 3:35 PM
When (online)	Mon 26 Oct, 11:25 AM	Mon 26 Oct, 3:35 PM
Points	1 per item	1 per item

- **Form mode:** quiz mode on, one point per item, answer key set, shuffle question order and options.
- **One attempt:** limit to one response; release scores after the review, not immediately, so answers do not spread during the quiz.
- **Privacy:** collect only name and office, the same identifiers as the attendance sheet. Do not collect birthdates, ID numbers or phone numbers. State this in the form's description.
- **Plain language:** items avoid trick wording. Every question tests one idea from the learner guide's Check yourself questions and desk card.
- **Printed backup:** print the items without the answer column, one copy per participant plus spares, with an answer sheet. Score by hand with the key at the end of this document.
- **Review:** after the time ends, review the two or three items most people missed, using the desk card phrases.

Quiz 1: Threat landscape and legal governance

15 items: threats and impact (5), Data Privacy Act (6), ISO/IEC 27001 (3), ASEAN AI guide (1). Twelve are multiple choice, five of them short scenarios, and three are true or false.

Threats and impact

1. (Scenario) Someone changes the e-wallet numbers on a payout list so the money goes to the wrong people. Which of Secret, Correct, Ready is hit first?

- A. Secret (confidentiality)
- B. Correct (integrity)
- C. Ready (availability)
- D. None, because no data left the office

Answer: **B.** The data was altered, which is an integrity failure. Source: Lesson 1.1.

2. According to Microsoft's Digital Defense Report 2025, what drove more than half of the attacks with a known motive?

- A. Espionage by state-linked groups
- B. Extortion and ransomware
- C. Hacktivism
- D. Accidents by employees

Answer: **B.** More than 52% involved extortion or ransomware; only 4% were espionage. Source: Lesson 1.1, What the numbers say.

3. Which measure did Microsoft report can block more than 99% of identity-based attacks?

- A. Changing passwords every month
- B. Multi-factor authentication
- C. Antivirus software
- D. A firewall

Answer: **B.** Source: Lesson 1.1, What the numbers say.

4. (True or false) Most harm caused by insiders is deliberate and malicious.

Answer: **False.** Most insider harm is accidental, such as sending files through personal accounts to work faster. Source: Lesson 1.1, Who attacks.

5. (Scenario) An email that looks like it comes from your IT unit says your mailbox will be deleted in one hour unless you log in through its link. What is this, and what should you do?

- A. An exposed website; ignore it
- B. Phishing; do not click, check with IT through a number you already know, and report it
- C. A shared account problem; forward it to your colleagues
- D. An old system warning; restart your computer

Answer: **B.** Urgency plus a login link is a classic phishing sign (door 1). Source: Lesson 1.1, Five doors.

Data Privacy Act

6. (Scenario) An application form asks for each applicant's religion, but the office never uses that information. Which principle does this break?

- A. Transparency

- B. Legitimate purpose
- C. Proportionality
- D. Data portability

Answer: **C.** Proportionality (Little): collect only what the purpose needs. Source: RA 10173, Sec. 11; Lesson 1.2.

7. (Scenario) The RSSO hires a vendor to send SMS notices to applicants, using the RSSO's list and following its instructions. Under the DPA, the vendor is a:

- A. Data subject
- B. Personal information controller
- C. Personal information processor
- D. Data Protection Officer

Answer: **C.** A processor handles personal data on the controller's behalf and instructions. Source: RA 10173, Sec. 3(i).

8. An applicant asks the office to correct a wrong birthdate in her record. Which right is she using?

- A. The right to object
- B. The right to rectification
- C. The right to data portability
- D. The right to damages

Answer: **B.** Source: RA 10173, Sec. 16; Lesson 1.2, rights.

9. Which of these is a physical security measure?

- A. Multi-factor authentication
- B. A privacy manual
- C. Locked filing cabinets and shredding
- D. Encryption

Answer: **C.** A and D are technical; B is organizational. Source: RA 10173, Sec. 20; Lesson 1.2.

10. When must the office notify the NPC of a breach that meets the notification conditions?

- A. Within 72 hours of knowing or reasonably believing that it happened
- B. Within 72 hours after the investigation proves it happened
- C. Within 5 days of discovery
- D. Only if the media reports it

Answer: **A.** Certainty is not required. Five days is the deadline for the full report. Source: NPC Circular 16-03, Sec. 17.

11. (Scenario) A clerk emails a list of 150 beneficiaries' names and government ID numbers to a wrong outside address. Using the 3S test, what is the best decision?

- A. No notification, because it was an accident

- B. Notify the NPC and the people affected within 72 hours: the data is sensitive, an unauthorized person received it, there is a real risk of serious harm, and with 100 or more people there can be no delay
- C. Wait until the recipient confirms that the email was deleted
- D. Notify the people affected, but not the NPC

Answer: **B.** Government ID numbers are sensitive and enable identity fraud. Source: NPC Circular 16-03, Secs. 11, 13 and 17.

ISO/IEC 27001

12. ISO/IEC 27001:2022 Annex A has 93 controls in four themes. Which theme has the most controls?

- A. People
- B. Physical
- C. Technological
- D. Organizational

Answer: **D.** Organizational has 37 (People 8, Physical 14, Technological 34). Source: Lesson 1.2.1.

13. (True or false) An office must be certified to ISO/IEC 27001 to comply with the Data Privacy Act.

Answer: **False.** The DPA requires security measures, not certification. Source: Lesson 1.2.1, For your office.

14. Which ISO/IEC 27001 document lists which Annex A controls apply, which do not, and why?

- A. The risk register
- B. The Statement of Applicability
- C. The privacy notice
- D. The incident report

Answer: **B.** Source: Lesson 1.2.1.

ASEAN AI guide

15. (True or false) The ASEAN Guide on AI Governance and Ethics is a binding law that every ASEAN government office must follow.

Answer: **False.** It is a voluntary guide, unveiled on 2 February 2024. In the Philippines, the binding rules for AI that processes personal data come from the DPA, as explained in NPC Advisory 2024-04. Source: Lesson 1.2.2.

Quiz 2: Assessing cyber risks and threat modeling

12 items: vulnerabilities and personal data (4), threat modeling and risk (5), attacks aimed at people (3). Ten are multiple choice, four of them short scenarios, and two are true or false.

Vulnerabilities and personal data

1. In the house comparison used in class, an unlocked window is the:

- A. Asset
- B. Threat
- C. Vulnerability
- D. Control

Answer: **C.** A vulnerability is a weakness a threat can use. Source: Lesson 2.1.

2. (Scenario) A contractor left two months ago but can still log in through the VPN. Where does this weakness sit?

- A. People
- B. Process
- C. Technology
- D. Physical security

Answer: **B.** There is no routine to remove access when people leave. Source: Lesson 2.1.

3. In Verizon's 2026 Data Breach Investigations Report, what was the most common way attackers first got in?

- A. Stolen passwords
- B. Exploiting vulnerabilities
- C. Stolen laptops
- D. Insider mistakes

Answer: **B.** 31% of breaches, ahead of credential abuse at 13%. Source: Lesson 2.1, What the numbers say.

4. (True or false) A weakness with a High CVSS score must always be fixed before one with a Medium score.

Answer: **False.** CVSS measures technical severity; the impact on your office also decides the order. Source: Lesson 2.1.

Threat modeling and risk

5. On a data flow map, a dashed line shows:

- A. A data store
- B. A trust boundary
- C. A person outside the system
- D. Encrypted traffic

Answer: **B.** Source: Lesson 2.2, Step 1.

6. (Scenario) Someone logs in to the portal with a clerk's stolen password. Which STRIDE threat is this?

- A. Spoofing
- B. Tampering
- C. Repudiation
- D. Denial of service

Answer: **A.** Pretending to be someone else. Source: Lesson 2.2, Step 2.

7. (Scenario) Five staff share one login, so no one can tell who approved a payout. Which STRIDE threat does this enable?

- A. Information disclosure
- B. Repudiation
- C. Elevation of privilege
- D. Spoofing

Answer: **B.** Without individual records, anyone can deny an action. Source: Lesson 2.2, Step 2.

8. A risk is rated likelihood 3 and impact 4. On the course's 5 by 5 matrix, what are its score and band?

- A. 7, Medium
- B. 12, High
- C. 12, Medium
- D. 16, Critical

Answer: **B.** 3 × 4 = 12, in the High band (10 to 16). Source: Lesson 2.2, Step 4.

9. (Scenario) The office stops collecting applicants' religion because it never uses it. Which TARA treatment is this?

- A. Transfer
- B. Avoid
- C. Reduce
- D. Accept

Answer: **B.** Stopping the activity removes the risk. It also follows the Little principle. Source: Lesson 2.2, Step 4.

Attacks aimed at people

10. (Scenario) A supplier emails to say its bank account has changed and asks that today's payment go to the new account. What should you do?

- A. Pay, because the supplier is known to the office
- B. Reply to the email to confirm the change
- C. Call the supplier on the number already in your records, and get a second approval

- D. Forward it to colleagues for their opinion

Answer: **C.** Replying reaches whoever sent the email, possibly the attacker. Source: Lesson 2.3, Defense in layers.

11. In SLAM, what does the L ask you to check?

- A. Language
- B. Links
- C. Location
- D. Login

Answer: **B.** Sender, Links, Attachments, Message. Source: Lesson 2.3.

12. (True or false) A caller who says he is from law enforcement may be given your one-time code if he already knows your name and address.

Answer: **False.** Never share a one-time code with anyone; knowing your details does not prove who he is. Source: Lesson 2.3.

Answer keys at a glance

Quiz	1	2	3	4	5	6	7	8	9	10	11	12	13	14
Quiz 1	B	B	B	F	B	C	C	B	C	A	B	D	F	B
Quiz 2	C	B	B	F	B	A	B	B	B	C	B	F		

F = False. Shuffling in the form changes the letters participants see, but the form marks by answer, not by letter.